

# API SECURITY RISK ANALYSIS REPORT

Task 3 — Future Interns Cybersecurity Internship

---

Target API: JSONPlaceholder (jsonplaceholder.typicode.com)

Prepared by: Richmond Delmas

Organization: Future Interns

Date: April 4, 2026

Tool: Postman + Browser DevTools

---

## 1. Executive Summary

---

This report presents the findings of an API security risk analysis performed on the public demonstration API JSONPlaceholder. The assessment was conducted as part of the Future Interns Cybersecurity Internship — Task 3.

The analysis was performed using Postman and Browser DevTools, following ethical guidelines (read-only access, no exploitation). Three major security risks were identified:

- Missing authentication on all endpoints
- Excessive sensitive data exposure (names, emails, addresses, GPS)
- Missing HTTP security headers

## 2. Scope & Ethical Guidelines

---

### What was **ALLOWED**:

- Testing public/demo APIs only
- Read-only GET requests
- Inspecting headers and API responses

### What was **FORBIDDEN**:

- Any exploitation or bypass attempts
- Flood tests / DoS attacks
- Attacking private or production APIs

This assessment was performed with the mindset of a security consultant, not an attacker. All testing was ethical and legal.

## 3. Tools Used

---

| Tool             | Purpose                                | Platform                     |
|------------------|----------------------------------------|------------------------------|
| Postman          | Send API requests, inspect responses   | Windows Desktop              |
| Browser DevTools | Inspect HTTP headers & network traffic | Chrome — Windows             |
| JSONPlaceholder  | Public demo API (test target)          | jsonplaceholder.typicode.com |

## 4. API Endpoints Tested

---

| Endpoint  | Data Exposed                          | Status | Risk     |
|-----------|---------------------------------------|--------|----------|
| /users    | Names, emails, addresses, GPS, phones | 200 OK | HIGH     |
| /posts    | Internal publications (7.98 KB)       | 200 OK | HIGH     |
| /comments | Emails + comments (40.77 KB)          | 200 OK | CRITICAL |

## 5. Identified Vulnerabilities

---

### Vulnerability #1 — Missing Authentication

|                      |                                                                                                                                              |
|----------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Risk Level           | <b>HIGH</b>                                                                                                                                  |
| Affected Endpoints   | /users, /posts, /comments                                                                                                                    |
| What is it?          | All API endpoints are accessible without any authentication. No API key, no password, no token is required.                                  |
| Why is it dangerous? | Anyone on the internet can read all user data without any authorization. A real company would face serious legal and financial consequences. |
| How to fix it?       | Implement API key authentication or OAuth 2.0 token-based access control for all endpoints.                                                  |

### Vulnerability #2 — Excessive Data Exposure

|                    |                                                                                                                       |
|--------------------|-----------------------------------------------------------------------------------------------------------------------|
| Risk Level         | <b>CRITICAL</b>                                                                                                       |
| Affected Endpoints | /users, /comments                                                                                                     |
| Data Exposed       | Full names, email addresses, physical addresses, GPS coordinates, phone numbers — 40.77 KB of data freely accessible! |

|                             |                                                                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Why is it dangerous?</b> | This violates GDPR and data protection laws. Users' private information is completely exposed to any third party without consent.           |
| <b>How to fix it?</b>       | Apply data minimization — only return fields necessary for each use case. Mask sensitive data such as emails, phone numbers, and addresses. |

### Vulnerability #3 — Missing Security Headers

|                             |                                                                                                                                          |
|-----------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Risk Level</b>           | <b>MEDIUM</b>                                                                                                                            |
| <b>Missing Headers</b>      | X-Frame-Options, Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options                                              |
| <b>What is it?</b>          | The API response does not include important security headers that protect users against common web attacks.                              |
| <b>Why is it dangerous?</b> | Without these headers, the API is vulnerable to clickjacking, cross-site scripting (XSS), and MIME-type attacks.                         |
| <b>How to fix it?</b>       | Add X-Frame-Options: DENY, Content-Security-Policy, Strict-Transport-Security, and X-Content-Type-Options: nosniff to all API responses. |

## 6. Risk Summary

| Vulnerability            | Risk Level | Priority           |
|--------------------------|------------|--------------------|
| Missing Authentication   | HIGH       | Fix Immediately    |
| Excessive Data Exposure  | CRITICAL   | Fix Immediately    |
| Missing Security Headers | MEDIUM     | Fix Within 30 Days |

## 7. Conclusion

This API security assessment of JSONPlaceholder revealed three significant security vulnerabilities that would pose serious risks in a real production environment.

The most critical issue is the complete absence of authentication, allowing unrestricted access to all user data including personal information, addresses, and GPS coordinates — a direct violation of data protection regulations such as GDPR.

Immediate remediation should focus on:

- Implementing strong API authentication (OAuth 2.0 or API keys)
- Applying data minimization to limit fields exposed by the API
- Adding required HTTP security headers to all API responses

---

*This assessment was conducted ethically using read-only methods only. No exploitation or unauthorized access was attempted.*

---